

Plan de Implementación Práctica del SGSI (Kali Linux y Administrativo)

Para cumplir con el requerimiento de implementación práctica de la ISO 27001, demostraremos la aplicación de las 6 políticas fundamentales de la organización combinando controles organizacionales (herramientas de gestión) y controles tecnológicos (utilizando **Kali Linux**).

A continuación, la propuesta exacta de los entregables prácticos para respaldar cada política:

Política ISO 27001	Tipo de Práctica	Propuesta de Implementación Práctica	Evidencia para el Profesor
1. Política General de Seguridad (A.5.1)	Administrativa	Formulario de Aceptación y Compromiso: Como la política establece la "Obligatoriedad" y "Sanciones", la implementación práctica es crear el formato real de un documento donde los empleados firman aceptando estas reglas, junto con un "Acta de Aprobación" firmada por el CEO ficticio.	Documento PDF "Acta de Aprobación del SGSI y Formulario de Aceptación del Empleado".
2. Política de Control de Acceso (A.5.15, A.5.17)	Técnica (Kali Linux)	Configuración de PAM y Expiración de Claves: Configurar el módulo <code>pam_pwquality</code> en Kali para forzar la creación de contraseñas de mínimo 12 caracteres (mezclando símbolos y números). Usar el comando <code>chage</code> para forzar la expiración de la clave a los 90 días.	Capturas de pantalla editando <code>/etc/pam.d/common-password</code> , el comando <code>chage -M 90</code> , y la terminal rechazando una clave corta.
3. Política de Copias de Seguridad (A.8.13)	Técnica (Kali Linux)	Script Bash y Automatización con Cron: Crear un script en Bash (<code>backup.sh</code>) que use el comando <code>tar</code> para comprimir una carpeta de datos críticos simulados, le asigne la fecha al nombre del archivo, y programarlo para que se ejecute de forma automática todos los días a medianoche usando <code>crontab</code> .	Código del script en Bash y captura de la salida del comando <code>crontab -l</code> demostrando la automatización diaria.
4. Uso Aceptable de Activos y Trabajo Remoto (A.8.1)	Técnica (Kali Linux)	Cifrado de Volumen con LUKS: Para cumplir la regla de "disco duro cifrado", crearemos un contenedor o formatearemos una partición pequeña utilizando LUKS (<code>cryptsetup</code>), que es el cifrado nativo de Linux, simulando la protección de la laptop.	Captura de pantalla de la terminal usando <code>cryptsetup luksFormat</code> y el sistema solicitando la contraseña (passphrase) para montar el disco.

5. Seguridad Física y del Entorno (A.7.7, A.7.1)

Técnica y Administrativa

Bloqueo Automático y Checklist:
Configurar en el entorno de escritorio de Kali (ej. XFCE Power Manager) el bloqueo automático de pantalla tras 5 minutos de inactividad (para cumplir A.7.7). Además, crear un Checklist en Excel para auditar el Data Center.

Captura de pantalla de la configuración de energía/pantalla en Kali Linux, y documento "Checklist de Seguridad Física" en PDF.

6. Seguridad en RRHH y Segregación de Funciones (A.6.2, A.5.3)

Administrativa

Firma de NDA y Matriz de Segregación: Presentar una plantilla real de Acuerdo de Confidencialidad (NDA). Además, mostrar una pequeña matriz (Excel) donde se evidencie claramente el "Maker-Checker", demostrando que el rol "Cajero" no puede ser el "Auditor".

Documento PDF del "Acuerdo de Confidencialidad (NDA)" y Excel de "Matriz de Segregación de Funciones".

